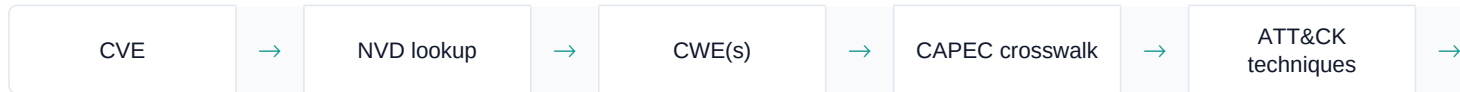


Vulnerability Exploitability — How the Logic Works

CVE → CWE → CAPEC → ATT&CK, the fallbacks, the Exploit-Test gate, and the scores. Generated from the live engine and this tenant's real data.

1. The pipeline, in one line

For every finding we build an attack picture from its identifiers, then test each step against the specific host it sits on:



Two inputs actually drive the technique selection: the **CWE(s)** (the weakness class) and the **CVSS vector** (how it's exploited). Everything else — EPSS, KEV, exploit maturity, exposure — colours the *scores* and the *reachability*, not which techniques apply.

2. Where each input comes from

CVE	The scanner (Nessus) report	—
CWE(s)	NVD enrichment (or, rarely, the scanner plugin's own xref)	the CVE id
CVSS vector	The scanner (NVD backfills only if the scanner left it blank)	—
EPSS	FIRST.org, live	the CVE id
KEV	CISA Known-Exploited catalogue	the CVE id
Exploit maturity	GitHub PoC search + Exploit-DB (our verdict from the counts)	the CVE id
ATT&CK techniques	CWE→CAPEC crosswalk, + parent-walk, + analyst gap-filler, + CVSS-vector rules	the CWE(s)

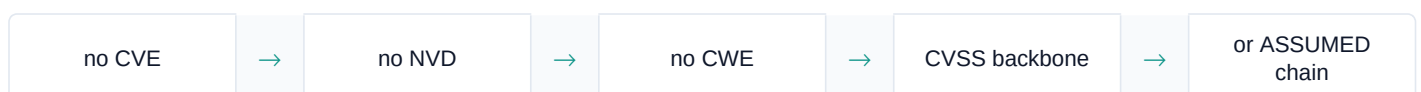
Note: no CVE means no NVD lookup, which means (almost always) no CWE — that is the hinge for the flows below.

3. Flow A — a finding WITH a CVE (the full path)



The CVE resolves (via NVD) to one or more CWEs. Each CWE is looked up in the authoritative CWE→CAPEC→ATT&CK crosswalk to pull the specific post-foothold techniques that weakness enables (web shell, token theft, adversary-in-the-middle...). On top, the **CVSS-vector rules** always add the entry-tactic backbone (network vector → “Exploit Public-Facing Application”, local → “Privilege Escalation”, user-interaction → “Client Execution”). Result: a rich, finding-specific chain.

4. Flow B — NO CVE received



With no CVE there is nothing to look up in NVD, so there is no CWE (unless the scanner itself carried one — only a handful of plugins do). The CAPEC / parent-walk / analyst tiers all have nothing to key on, so:

- If a **CVSS vector** is present (the scanner usually provides one even without a CVE) → the chain is the **CVSS-vector backbone** only: recon + the entry techniques the vector implies. Coarse, but honest — and flagged “*Generic mapping — no CWE*” in the UI so it is never dressed up as finding-specific.
- If there is **neither CWE nor vector** (a pure info detection) → an explicitly **ASSUMED** generic entry chain, marked low-trust, which the reachability layer almost always prunes to **Unlikely**. We never invent a confident path from nothing.

5. Flow C — a CWE, but NO direct CAPEC mapping (the parent-walk)



MITRE’s CWE→CAPEC crosswalk is sparse — many common weaknesses have no direct mapping. Rather than drop to the coarse CVSS backbone, we **climb the CWE “ChildOf” tree** to the nearest ancestor that *does* map and borrow its techniques — real MITRE standards data, just inherited from a broader parent, so it is labelled “**Standards (parent)**” with the climb depth and a lower confidence. It fires only on a direct miss, so it never overrides an exact hit. If even that finds nothing, the **analyst gap-filler** (well-known pairs CAPEC drops, e.g. SQL-injection → “Exploit Public-Facing Application”) applies, then the CVSS backbone.

Order of precedence, strongest first: **direct CAPEC > parent-walk (Standards-parent) > analyst > CVSS heuristic**.

On this tenant, of the 23 findings that carry a CWE: 10 hit CAPEC directly, and **13 rely on the parent-walk** — without it, those 13 would have collapsed to the thin CVSS backbone.

6. The Exploit-Test tab — when it shows, and how the attack runs “all the way”

When the tab appears. Only when an exploit is *actually available* — a public PoC / Exploit-DB entry — **or** the CVE is on CISA KEV. No exploit means there is nothing to exploit-test, so the tab is hidden; the reachability verdict still shows on the Analysis tab. EPSS does *not* open the tab (it is a forecast, already weighed in the score).

How the attack runs. When shown, the kill-chain walks the ATT&CK tactics in order and badges each technique by whether it can be reached on THIS host:

LIKELY	Reachable AND confirmed by a fact (KEV, or a verified public exploit).
POSSIBLE	Nothing on this host rules it out, but no exploit/KEV confirms it in the wild.
BLOCKED	A definite fact shuts it — e.g. the host is not internet-exposed, so a public-facing entry can’t be reached.
SEVERED	A later step the chain can’t reach because the entry “door” above it is blocked.

The “door”. The entry step (Initial Access / Execution) is the gate. If it is **BLOCKED** — most often because the asset is **internal, not internet-exposed** — the chain is **severed at the door**: every stage below is dimmed as theoretical, and the verdict caps at **Unlikely**. Exposure and attack-vector decide this: internet-facing + network vector → entry reachable; internal-only → entry blocked. A credential/information weakness whose entry is *not* gated by exposure can stay reachable even internally.

7. Three distinct scores (not one)



Composite priority	How urgent is this <i>finding</i> ? (7 signals: CVSS, EPSS, maturity, KEV, vector, exposure, asset)	0–100
Reachability verdict	Can it actually be exploited on <i>this host</i> ?	likely / possible / unlikely
Asset effective-risk	How much risk does <i>this asset</i> carry (business-impact weighted)?	band

The Vulnerabilities dashboard shows the headline of this: **Raw severity** → **Contextual priority** — what looks urgent by CVSS alone versus what is actually urgent once exposure, public exploits and EPSS are weighed.

8. Worked examples (this tenant's real findings)

CVE-2026-55180 CWE-200/201/522 (info & credential exposure)	Direct CAPEC + backbone	42 techniques, all 11 tactics	Possible — credential entry isn't gated by internal-only
CVE-2025-55130 CWE-289/281 (auth bypass)	Parent-walk (289→287, 281→732)	20 techniques; entry blocked	Unlikely — internal, chain severed at the door
A no-CWE info detection	CVSS backbone (Flow B)	~3 generic entry techniques	Unlikely — flagged "generic"

9. Which finding has the most tactics

CVE-2026-55180 — 11 of the 14 ATT&CK tactics, spanned by **42 techniques** (the richest chain). Three findings tie at 11 tactics (CVE-2026-55180, CVE-2013-3900, CVE-2025-55130), but 55180 is the deepest and, being a credential/information-exposure weakness, the only one of them that stays *reachable* on an internal host.

Derived from stored evidence only — no scanner, exploit or payload is ever run against a host. Approximate mappings (parent-walk, CVSS rules) are always labelled as such.